串接方式與交付清單

先選接法，再交換設定

要達成哪一種需求？

需求 / 方式	本地端需做什麼	取得資料
標準 OIDC 登入	支援 Code + PKCE 的後端用戶端	ID Token 與授權身分欄位
Web API 單一登入	登入啟動頁、回呼、後端兌換	JSON 身分資料；不是 Access Token
SAML 2.0 登入	SP 模組、簽署請求、ACS	簽章 Assertion 與授權屬性
JSON 帳密驗證	後端送使用者帳密驗證	只有 verified 布林值
舊 SOAP 相容介面	按方法及 WSDL 實作呼叫	陣列或 DataSet；目前 9 個方法
一般首頁連結	提供 HTTPS 網址	不傳送身分資料、不建立 SSO

1. **使用者瀏覽身分專區**
   學生、教職員、校友專區可先瀏覽；私人服務依登入及授權顯示。
2. **點選系統入口**
   OIDC / Web API / SAML 應進接收系統的登入啟動頁。
3. **接收系統發起中央驗證**
   中央有有效登入就沿用；沒有時顯示中央登入頁。
4. **接收系統驗證結果並建立自己的登入**
   帳號對應與業務權限由接收系統負責。

> 「Web API 單一登入」與「JSON 帳密驗證」是兩套不同介面。前者不用把使用者密碼交給對方；後者由對方收集帳密送來驗證，不會因此取得中央登入。

NKUST · DEVELOPER INTEGRATION

串接方式與交付清單

先選接法，再交換設定

雙方需要交換哪些資訊？

提供方	交付項目
接收系統	系統名稱、用途、承辦人、開發 / 維運窗口與聯絡方式；測試及正式網域。
接收系統	登入啟動網址、精確回呼網址；SAML 另交 SP Entity ID、ACS 與公開簽章憑證。
API / SOAP 呼叫端	實際對外來源 IP、需要的方法與欄位；SOAP 指定方法另需呼叫帳密或 fnc_id。
SSO 管理者	實際 SSO 基底網址、系統代碼、所選協定、啟用狀態及允許提供欄位。
SSO 管理者	適用模式的 Client Secret、Discovery / metadata / WSDL、合成測試帳號。密鑰另行安全交付。
雙方確認	帳號對應方式、未開通帳號處理、權限、Session 期限、登出範圍與驗收窗口。

網址填法

用途	示意
SSO 基底網址	https://sso.example.edu/
接收系統登入啟動	https://app.example.edu/login
OIDC 回呼	https://app.example.edu/signin-oidc
Web API 回呼	https://app.example.edu/sso/callback
SAML ACS	https://app.example.edu/saml/acs

入口不填中央 /account/login，也不把回呼當作啟動頁。回呼需精確登記，包含 scheme、網域、埠號及路徑；測試與正式各自登記。若要另開分頁，入口可使用 target="_blank" 與 rel="noopener"，整個登入流程在新分頁完成。

> 中央與接收系統各自建立 Cookie / Session。中央登入有效可省略再次輸入帳密；接收系統仍須完成驗證。中央登出不等於所有下游同時登出，本版未實作完整跨系統單一登出。

交接與驗收

- 使用核准測試帳號完成正常、失敗、停用、重放及欄位授權測試；詳細案例見各模式文件。
- 核對本地帳號與權限、登入期限及登出行為後，再安排測試與正式環境的交接。

> 本文件為目前開發版介面規格；正式網址、系統代碼、密鑰 / 憑證、授權欄位與測試帳號請向 SSO 管理者取得。example.edu 為示意位址，不可直接呼叫。

實作核對：src/NkustSso.Server/Controllers/PortalServicesController.cs；Services/SsoSystemRegistrationService.cs；Services/IntegrationClientRegistrationService.cs